

ЛР 3

Провести симуляцию атаки по одной из предложенных уязвимостей
OWASP Top 10 - REST API

Цель

1. найти CVE, относящиеся к недостаткам REST API.
2. на предоставленном стенде найти хотя бы один недостаток из top-10 rest api

Описание/Пошаговая инструкция выполнения домашнего задания:

Часть I

Необходимо среди CVE за последний год найти 3 CVE, относящиеся к недостаткам REST API, входящим в owasp top-10 rest api. Пояснить, в чем заключается недостаток и какова его причина.

Ответ - текстовый файл с описанием.

Баллы за часть I

4 балла

Часть II

1. Скачать уязвимый образ с [docker.hub](https://hub.docker.com/r/ket9/otus-devsecops-owasp-rest), выполнив команду из консоли

```
docker pull ket9/otus-devsecops-owasp-rest
```

2. Запустить образ

```
docker run -d -p 8080:8080 ket9/otus-devsecops-owasp-rest:latest
```

3. Зайти на <http://localhost:8080/>, посмотреть, какой функционал доступен в приложении.

```
http://localhost:8080/
```

4. Наполнить базу данных, перейдя по ссылке <http://localhost:8080/createdb>

```
http://localhost:8080/createdb
```

После этого вторую часть задания можно выполнить в двух вариациях: либо самостоятельно попробовать найти какой-то недостаток в приложении из [owasp top-10 rest api](#), либо провести эмуляцию атаки (выполнить по шагам уже описанную уязвимость).

Вне зависимости от того, какой вариант вы выбираете, ответом на дз будет текстовый файл, содержащий:

1. ход ваших рассуждений, что пробовали делать, какой был ответ приложения, какие выводы вы из этого делали.
2. описание найденной уязвимости
3. к какому типу из 10 изученных относится недостаток
4. меры предотвращения

Баллы за часть II

6 баллов

Критерии оценки

Часть I

Условие	Баллы
найдена одна CVE	2 балла
найдено две	3 балла
три	4 балла

Часть II

Что описано в ответе	Баллы
описан ход рассуждений	2 балла
описан ход рассуждений, найденная уязвимость	2+2 балла
описан ход рассуждений, найденная уязвимость, тип	2+2+1 балла
описан ход рассуждений, найденная уязвимость, тип, меры предотвращения	2+2+1+1 балла

Минимальный проходной балл	5 баллов
Максимальное количество баллов за ДЗ	10

Содержимое задания перенесено в удобочитаемый формат: заголовки, команды, ссылки и критерии оценки визуально отделены друг от друга.